

Documentation Findings

Security Assessment Report

NodeGoat Application

Student Name	Fatima Haq
Course	Cybersecurity
Project Title	Securing the NodeGoat Application
Report Week	Week 3 — Advanced Security
Date	June 26, 2026
Tools Used	Nmap, OWASP ZAP, Winston, Browser DevTools

CONFIDENTIAL – For Educational / Internship Use Only

Executive Summary

Finding	Risk Level	Status
1. Stored XSS	High	Open
2. Open Network Ports	Medium	Open
3. Missing HTTPS	Medium	Open
4. Logging & Monitoring	N/A	Fixed
5. Security Checklist	N/A	Fixed

Detailed Findings

Finding 1: Stored Cross-Site Scripting (XSS)

Description

The application was vulnerable to Stored Cross-Site Scripting attacks. User-supplied input entered in the Address field was stored and executed by the browser.

Evidence

A browser popup displaying "XSS" appeared after revisiting the profile page, confirming that the injected script was persisted and later executed.

Risk Level: High

Recommendations

- Sanitize all user inputs before storing them.
- Encode output before rendering it in the browser.
- Enable automatic output escaping in the templating engine.
- Implement a strong Content Security Policy (CSP).

Finding 2: Open Network Ports

Description

"Port 4000 was intentionally exposed for local development purposes and does not represent a production risk." Nmap scanning identified open ports 135, 445, and 4000 on the target system. These ports expose services that may be exploitable if not properly secured.

Risk Level: Medium

Recommendations

- Restrict unnecessary ports using firewall rules.
- Expose only required services to the network.
- Disable unused services in production environments.

Finding 3: Missing HTTPS Implementation

Description

The application was running over HTTP during local development, transmitting data in plaintext and leaving it susceptible to interception.

Risk Level: Medium

Recommendations

- Enable HTTPS in all production environments.
- Use valid SSL/TLS certificates for secure communication.

Finding 4: Logging and Monitoring Improvement

Description

Initially, the application lacked centralized logging functionality, making it difficult to track events and detect anomalies.

Resolution

Winston logging was implemented to record important application events, providing visibility into system behavior and supporting incident response.

Status: Fixed

Finding 5: Security Best Practices Documentation

Description

The project did not initially contain a formal security checklist, leaving security controls undocumented and inconsistently applied.

Resolution

A SECURITY_CHECKLIST.md file was created to document implemented security controls and best practices, providing a baseline for future development.

Status: Fixed